

SSO / Auth implementation

Phase 1 session identity (not marketing OAuth hub)

Technical documentation | 19 September 2026 | Web + Python API + Convex

Business perspective

LangChat is a durable-memory assistant. Phase 1 auth is a browser session id so history sticks without forcing Google login. That lowers the barrier to try the product.

The problem (why this exists at all)

The Python lab stored chat in RAM. Refresh meant amnesia. Marketing SSO is a shared OAuth hub for three products - too heavy for a first LangChain demo.

Who the customer is

You (Deo) and anyone you send the LangChat URL to. They are not CRM contacts or LMS parents.

How money is supposed to move

This MVP does not bill. Value is proof that LangChain + Convex memory works on free tiers so you can sell custom AI chat with permanent history.

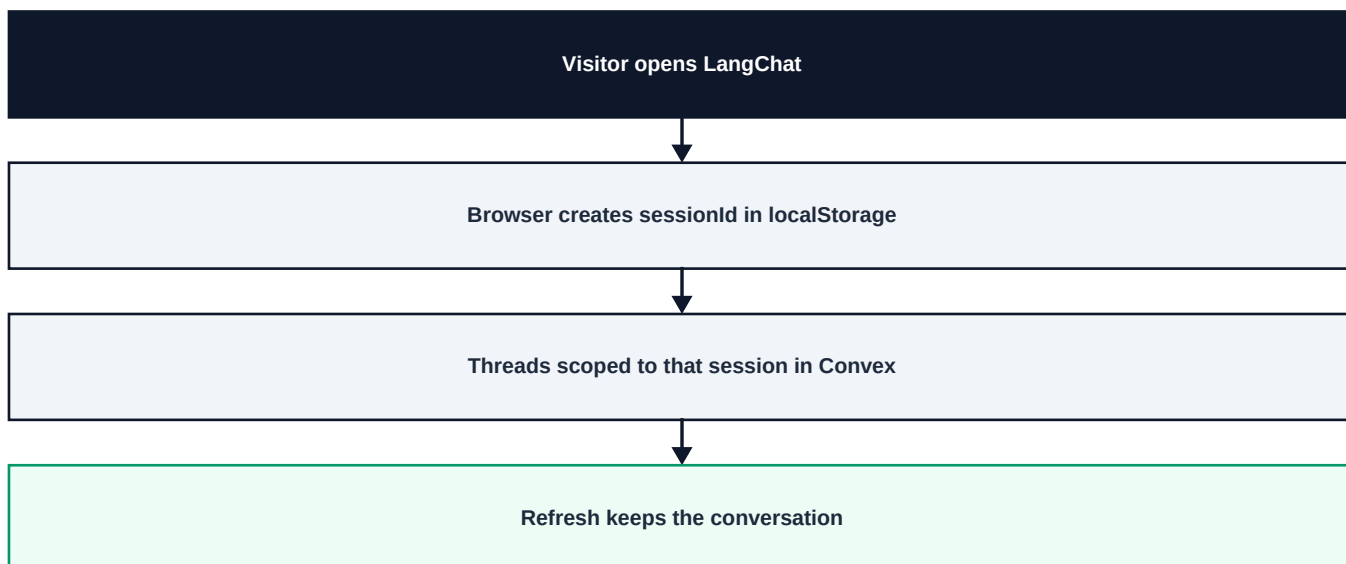


Figure B1. Phase 1 identity is a session cookie-equivalent, not Google OAuth.

How the business runs day to day

Step	In the real world	What this software is for
Arrive	Open the web app.	getSessionId() writes localStorage.
Chat	Send a message.	API checks thread.sessionId matches.

Return	Same browser later.	Same sessionId -> same threads.
Later SSO	Optional Google via Convex Auth.	Documented as Phase 2 - not required for MVP.

What 'winning' looks like (KPIs)

- Refresh does not wipe threads for the same browser.
- Another browser/session cannot read your threadIds (403 on mismatch).
- No Render wake page or marketing /auth/callback involved.

Do not register LangChat callbacks on the shared www Facebook/LinkedIn hub until Phase 2.

1. Purpose

This document describes how DMB LangChat identifies users in Phase 1 and how that differs from DMB Web Solutions / CRM / LMS OAuth SSO. Secrets are never stored here.

2. Phase 1 design

- Client generates a UUID sessionId and stores it in localStorage (dmb_langchat_session).
- Convex threads.sessionId scopes the thread list.
- POST /chat requires sessionId; API rejects thread access if sessionId mismatches.
- No JWT, no ExternalLogin table, no Vercel auth-external proxy.

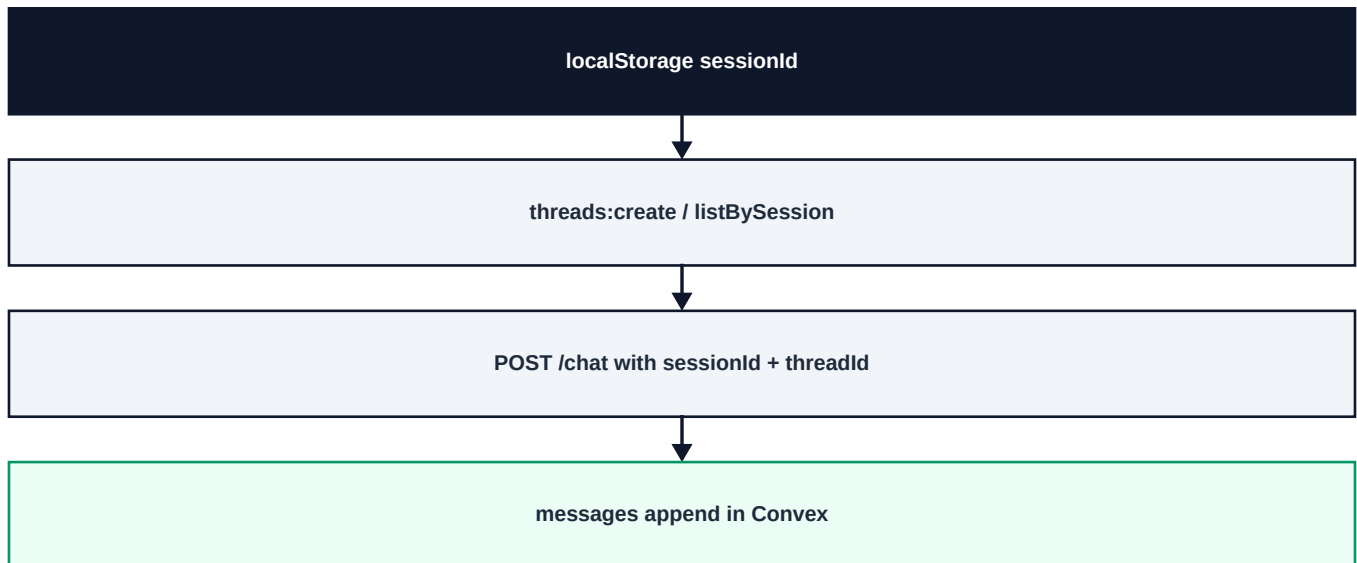


Figure 1. Auth surface for MVP.

3. Why not the marketing SSO hub

Marketing, CRM, and LMS share Google/Facebook/LinkedIn apps with state prefixes crm. / lms. LangChat is a fourth product. Wiring it into that hub before the chat loop works would slow delivery and burn Hobby serverless capacity on the marketing site.

4. Phase 2 (planned)

- Convex Auth with Google (or Clerk) issuing a user id.
- Replace sessionId with authenticated subject; migrate threads.
- Optional link from www.dmbwebsolutions.com/langchat via real navigation.

5. Environment (names only)

Name	Where	Role
CONVEX_URL	Render api	Deployment URL for convex-py
VITE_CONVEX_URL	Vercel web	Same deployment for ConvexReactClient
GOOGLE_API_KEY	Render api	Gemini for LangChain
VITE_API_URL	Vercel web	Public URL of the Python API

6. Security notes

- sessionId is bearer-like in the browser - anyone with the id can use that session.
- Do not log full message bodies with PII in Render logs.
- CORS_ORIGINS must list the production web origin.

End of document. Pair with DMB-LangChat-System-Architecture.pdf and DMB-LangChat-User-Guide.pdf.